Quand aux injections SQL basées sur le temps, on envoi des instructions conditionnelles SQL pour retarder la reponse de la page si l'instruction conditionnelle renvoi true en utilisant la fonction Sleep()
Enfin dans certains cas on a aucun accès direct à la sortie on doit la diriger vers un emplacement distant, "dans un enregistrement DNS", et la recuperer à partir de la l'injection est dite Out-of-Band.

Dans ce module on se concentrera sur les UNION BASE.

Détourner La Logique de La Requete:

On commence par tester si une entrée est vulnérable, on peu par exemple injecter des caractères spéciaux pour voir si cela provoque une erreur de base de donnée...
Il y a plusieurs forme d'injection le but étant de manipuler la logique & de la requête SQL afin d'obtenir une condition vrai pour ce faire il faut maitriser le langage SQL la priorité des operateurs - etc..
-Prenons un exemple de bypass de panel de login à l'aide d'un operateur OR
Imaginons que la requête soit:

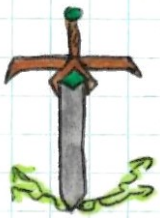
```
Select * from logins where username = 'admin' AND password = 'p@ss!';
```

Dans le champ de formulaire on inject ces payload:

```
something' OR '1'='1
```

La requete reconstruite donnera ainsi une reponse true bypassant le formulaire:

```
Select * from logins where username = 'something' OR '1'='1" AND password = 'something' OR '1'='1';
```



On peux également utiliser les commentaires pour detourner la logique des requêtes SQL. Le language SQL integre deux style de commentaire de ligne -- et # bien qu'il y en est un troisième il est generalement pas utilisé pour les injection (/**/). Notons que les deux tirait commentaire sons suivi qu'un espace donc en url encoding cadonne ca (--+) et pour # (%23)
Exemple pour l'injection basique = admin' -- une requete mal echappée donnera SELECT * FROM logins WHERE username = 'admin'-- AND password = 'somerong';
Il faut toujours essayé de comprendre comment la requete est précisement forgée pour la contourner.

On peu utiliser l'operateur UNION il sert à coller les resultats d'une deuxième requete à la suite d'une première, mais pour que ce collage fonctionne la base de donnée impose une règle absolue les deux requêtes doivent avoir exactement le même nombre de colonnes. On doit donc fabriquer autant de fausses colonnes à la volée en injectant des valeurs fixes (comme NULL, 'text', 1) juste pour faire le nombre et boucher les trous...
Exemple à injecter: UNION SELECT username, NULL, 2, 3 from passwords --'
On peu pour trouver le bon nombre de colonne on peu aussi utiliser l'operateur 'order by', suivi d'un numéro le but est de demander à la base de donnée de trier les resultats par la première colonne, si la page s'affiche correctement y a au moins une colonne, ensuite on incremente progressivement le numéro de la colonne (ORDER BY 2, ORDER BY 3, etc) jusqu'a generer une erreurre...

Enumération De La Base de Donnée:

Pour identifier si la SGBD est MySQL on a plusieurs "payload" donnons en un:

```
SELECT @@version
```

La base de donné par default information_schema (MySQL) contient des metadonnées sur la base de donné, les tables et les colonnes, ce qui la rend essentielle pour l'enumeration, Notons que pour faire référence à une table presente dans une autre base de donnée on utilise l'operateur (.). Ex: select * from my_db.users;
Il y a trois table dans information_schema:
SHEMATA => Trouver les noms de base de donnée